

Smart Contract Re-audit Report

MoonsaleTokenFactory

BNB Smart Chain · Solidity ^0.8.20

ENGAGEMENT METADATA

REPORT ID	ICG-2026-MSL-008 (Re-audit R1 of MSL-007)
CLIENT	Moonsale App
SCOPE	MoonsaleTokenFactory.sol (revised)
COMMIT / VERSION	Single source file, 137 SLOC, post-remediation revision
METHODOLOGY	Manual re-audit, remediation verification
ISSUE DATE	April 23, 2026

Executive Summary

This report is a re-audit of MoonsaleTokenFactory, following the client's remediation of the findings raised in ICOGemHunters audit ICG-2026-MSL-007 (issue date April 23, 2026). The revised source is 137 SLOC, up from 122, with the added code dedicated to a pull-pattern fee claim flow, reentrancy protection on all payable functions, strict fee matching at the entry points, a hard ceiling on creationFee, and richer creation events. Every prior finding has an explicit in-code comment referencing its ID (// M-01, // L-02, etc.) tying the implementation back to the prior recommendations.

Of the 8 prior findings: 7 are now fully Fixed and 1 is Acknowledged (I-03, the build-pipeline compiler target). Both Medium items are closed: M-01 adopts the strict-equality option (`msg.value == creationFee`) rather than the refund option, which is simpler and eliminates an additional external call to `msg.sender`. M-02 adds `nonReentrant` to all three fee-handling functions: `createToken`, `createLiquidityToken`, and the new `withdrawFees`. All three Low items are closed with constructor validation, the pull-pattern fee claim, and a hard-coded `maxCreationFee = 1` ether ceiling. Both actionable Info items are closed. No new findings were identified in this round.

The fixes were verified end-to-end. The new `withdrawFees` function follows checks-effects-interactions order: `pendingFees = 0` precedes the external call, `require(sent)` reverts on send failure restoring state. The `nonReentrant` modifier on all three fee-handling functions uses the shared OpenZeppelin guard, so cross-function reentry from a malicious `router_` during child construction or a malicious `feeRecipient` during withdrawal is blocked. The `maxCreationFee` is declared constant, hard-coding the ceiling at the bytecode level and removing any future owner path to exceed it.

The security score rises from 80/100 in the prior report to 93/100 in this re-audit, a 13-point improvement. The 7-point residual deduction reflects the Acknowledged compiler-target concern (I-03) and a general reserve for items outside manual-review scope such as formal verification of fee accounting under extreme edge conditions. The contract is production-ready.

Score Comparison

	Prior Audit (MSL-007)	Re-audit (MSL-008)
Critical	0	0
High	0	0
Medium	2	0
Low	3	0
Info	3	0 new · 1 ack
Total new findings	8	0
Security Score	80 / 100	93 / 100

Remediation Status

Every finding from the prior audit was verified against the revised source. The table below lists each prior finding with its current status, a reference to the line or function that implements the fix, and a note on the verification outcome.

ID	Sev	Title	Status	Verification Note
M-01	Medium	msg.value overpayment forwarded to fee recipient	Fixed	Strict equality check <code>msg.value == creationFee</code> at lines 64 and 92. Overpayment reverts cleanly rather than being absorbed. Chose the alternative option from the recommendation (tighten rather than refund), which is simpler and avoids an additional external call to <code>msg.sender</code> .
M-02	Medium	No reentrancy guard on payable creation functions	Fixed	<code>ReentrancyGuard</code> imported and inherited (lines 5, 12). <code>nonReentrant</code> modifier applied to <code>createToken</code> (line 63), <code>createLiquidityToken</code> (line 91), and the new <code>withdrawFees</code> (line 116). All three fee-handling paths share the guard.
L-01	Low	Constructor does not validate <code>feeRecipient_</code>	Fixed	<code>require(feeRecipient_ != address(0))</code> added at line 46. Restores symmetry with <code>setFeeRecipient</code> .
L-02	Low	Token creation DOSed by reverting <code>feeRecipient</code>	Fixed	Pull pattern implemented (Option A of the recommendation). <code>pendingFees</code> accumulates on each creation (lines 74, 107); new <code>permissionless withdrawFees()</code> at lines 116-122 sends the balance to <code>feeRecipient</code> with CEI order. Creation liveness is now independent of fee recipient behaviour.
L-03	Low	No upper bound on <code>creationFee</code>	Fixed	Public constant <code>maxCreationFee = 1 ether</code> (line 14), enforced in both the constructor (line 47) and <code>setCreationFee</code> (line 127). Cap is hard-coded rather than immutable, so it cannot be raised via a separate setter.
I-01	Info	Events omit <code>maxSupply</code> and fee parameters	Fixed	<code>TokenCreated</code> now includes <code>maxSupply</code> as an additional parameter (line 26). <code>LiquidityTokenCreated</code> now includes <code>liquidityFee</code> and <code>marketingFee</code> (lines 38-39). Events are emitted with the new values (lines 76, 109-112).
I-02	Info	Constructor emits no initial Fee events	Fixed	Lines 50-51 emit <code>FeeUpdated(0, creationFee_)</code> and <code>FeeRecipientUpdated(address(0), feeRecipient_)</code> at the end of the constructor, giving indexers a uniform event-driven model across deploy and update paths.
I-03	Info	Compiler EVM target for BSC	Acknowledged	Deployment-time note, unchanged. Confirm Shanghai support on target nodes before deploying.

Scope & Methodology

In-Scope Files

File	Role	Reviewed
<code>MoonsaleTokenFactory.sol</code>	Factory contract for deploying <code>MoonsaleToken</code> and <code>MoonsaleLiquidityToken</code> instances; revised after MSL-007	Yes

R1 Methodology

- Line-by-line diff between MSL-007 source (122 lines) and the revised source (137 lines), with the 8 prior findings used as an explicit verification checklist.
- Verified the new `withdrawFees` function for checks-effects-interactions order, reentrancy safety under the shared `nonReentrant` guard, and state-restoration on send failure.
- Traced the `pendingFees` accounting across all three fee-handling paths to confirm no overflow, no double-counting, and no path where fees are silently dropped or orphaned.
- Verified the strict-equality constraint `msg.value == creationFee` handles the zero-fee case correctly (`msg.value == 0` is accepted when `creationFee == 0`).
- Confirmed the constant declaration of `maxCreationFee` at line 14 embeds the ceiling into bytecode and cannot be bypassed by any setter or upgrade path.
- Fresh pass over the full contract to detect any new attack surface introduced by the changes: none identified. The refactor adds only defensive state and does not alter the external interface in ways that could be exploited.
- Verified that `MoonsaleToken.sol` and `MoonsaleLiquidityToken.sol` are still referenced as the audited versions (MSL-006 97/100 and MSL-005 94/100 respectively).

Severity Classification

Severity	Definition
Critical	Direct loss of user or protocol funds, or unilateral takeover.
High	Realistic exploit with significant impact.
Medium	Conditional impact or material UX or availability concern.
Low	Limited impact; defence in depth.
Informational	Code quality, gas, documentation.

New Findings

No new findings were identified in this round. The R1 revision adds five substantive changes (strict equality on `msg.value`, `nonReentrant` on three functions, constructor zero-address check, pull-pattern fee claim, `maxCreationFee` constant ceiling, enriched events, and constructor event emission); each change was verified to be correct, to preserve the prior safety properties, and to introduce no new attack surface.

Carryover Acknowledged Item

One prior item remains Acknowledged rather than Fixed. It is a build-pipeline concern outside the contract source.

- I-03 Compiler EVM target. `pragma solidity ^0.8.20` with default settings emits PUSH0. BSC mainnet supports Shanghai; deployments to forked, archive, or lagging nodes require explicit settings: `{ evmVersion: "paris" }` in the build configuration. Addressed at the build-pipeline level, not in the contract source.

Positive Observations

- Round-1 remediation mirrors the recommendations in MSL-007 with high fidelity: M-01 adopts the strict-equality alternative (simpler than the refund path), L-02 implements Option A (pull pattern) verbatim, L-03 enforces the ceiling in both the constructor and the setter as suggested.
- The strict-equality check `msg.value == creationFee` is superior to the refund alternative: it requires no additional external call, no second `nonReentrant` surface, and no edge-case handling for refund failure. The tradeoff (UX revert if fee is mid-mempool-changed) is acceptable because the user's ETH is returned on revert.
- `maxCreationFee` is declared constant rather than `immutable`, hard-coding the ceiling at the bytecode level. This is stronger than the `immutable` pattern suggested in MSL-007 because no constructor argument can influence it.
- The new `withdrawFees` function is permissionless, which is the correct design given that the destination is fixed (`feeRecipient`). Any third-party keeper can trigger the claim, reducing the operational burden on the fee recipient.
- The three `nonReentrant` functions (`createToken`, `createLiquidityToken`, `withdrawFees`) share the OpenZeppelin reentrancy guard, so cross-function reentry from any hostile external address is blocked. This includes the user-controlled `router_` during child construction and the owner-controlled `feeRecipient` during withdrawal.
- Constructor validation is symmetric with setter validation: `feeRecipient_ != address(0)` at line 46, `creationFee_ <= maxCreationFee` at line 47. A fresh deployment cannot land in a state that the setters would have rejected.
- Initial `FeeUpdated` and `FeeRecipientUpdated` events are emitted at the end of the constructor (lines 50-51) with the convention that the "old" value is zero. Indexers can now reconstruct the full fee-and-recipient history from events alone without a special-case read of the deployment block.
- The events `TokenCreated` and `LiquidityTokenCreated` now include the economically significant parameters (`maxSupply`, `liquidityFee`, `marketingFee`), letting subgraphs display deployed-token properties without a secondary contract read.
- The refactor introduces no new external surface beyond `withdrawFees`, which itself is reviewed for reentrancy, CEI order, and send-failure behaviour. The contract's attack surface has not grown.
- Every prior-audit finding has an explicit in-code comment referencing its ID (`// M-01`, `// L-02`, etc.) at the point of remediation. Future reviewers can trace every fix to its motivating finding in seconds.

Out of Scope and Assumptions

- OpenZeppelin v5 base contracts (Ownable, ReentrancyGuard) are not re-audited and are assumed canonical.
- The child contracts deployed by this factory (MoonsaleToken and MoonsaleLiquidityToken) are assumed to be the revisions cleared in ICG-2026-MSL-006 and ICG-2026-MSL-005 respectively. Redeploying this factory with different or modified child contracts invalidates both this report's delegation assumptions and the child reports' validity.
- The factory owner is assumed to be trusted for the specific powers granted by Ownable: setting the creation fee (bounded by `maxCreationFee = 1 ether`), rotating the fee recipient, and transferring ownership. The owner has no path to mint tokens, modify deployed token state, or seize beyond-pending fees.
- Users calling `createLiquidityToken` are assumed to supply a trusted router address. A malicious `router_` harms only the caller's own deployed token (produces a broken pair immutable) and cannot affect other users or the factory state beyond the reentrancy surface, which is now guarded.
- Deployment is assumed to target a Shanghai-enabled EVM as discussed in I-03.
- No off-chain components are in scope.

Summary and Final Position

The R1 revision of MoonsaleTokenFactory closes every actionable finding from the prior audit. Seven of the eight items are Fixed with code-level changes that match or improve on the prior recommendations; the remaining item is formally Acknowledged as a build-pipeline concern. No new findings were introduced. The factory's attack surface is now well-guarded: all payable and fee-handling entry points are nonReentrant, fee accounting uses a pull pattern that decouples creation liveness from recipient behaviour, the creation fee is bounded by a hard-coded ceiling, and every admin mutation emits a complete event history.

Engagement Progression

The factory was first audited as MSL-007 and produced 8 findings concentrated in fee handling (M-01 overpayment absorption) and reentrancy posture (M-02 missing guard), with three Low and three Informational hardening items. This R1 re-audit (MSL-008) confirms the resolution of all 7 actionable items and records the compiler target (I-03) as an accepted build-pipeline trade-off. The score has improved by 13 points. The factory is production-ready.

SECURITY SCORE

80 → 93 / 100

Moonsale Engagement — Pipeline Status

With this report, all three principal deployable contracts of the Moonsale engagement have been audited and cleared:

Contract	Final Score	Cleared Report	Status
MoonsaleToken	97 / 100	MSL-006 (R2)	Production-ready
MoonsaleLiquidityToken	94 / 100	MSL-005 (R2)	Production-ready
MoonsaleTokenFactory	93 / 100	MSL-008 (R1)	Production-ready

Disclaimer

This report is a point-in-time re-audit of the source code revision provided to ICOGemHunters following the remediation of audit MSL-007. Findings reflect the state of the code at the commit or version indicated on the cover page. Any modification made after that point, whether by the client or a third party, invalidates the specific conclusions drawn herein.

The assessment is advisory. It does not constitute a warranty, guarantee, or insurance policy against exploits, operational failures, or economic losses. Smart contract security cannot be proven exhaustively; the absence of a finding is not a proof of absence of vulnerability. ICOGemHunters applied professional diligence and the methodology described in this document, no more and no less.

This report is not financial, legal, tax, or investment advice. Nothing in this document should be interpreted as an endorsement of the token, project, team, or any associated economic activity. Decisions to acquire, hold, transact in, or interact with MoonsaleTokenFactory remain the sole responsibility of the user.

ICOGemHunters accepts no liability for losses, damages, or consequences arising from the client's decision not to implement the recommendations contained in this report, or from reliance on this report by any third party. The report is prepared for the named client and may not be reproduced in part without preserving this disclaimer in full.

This report audits the factory in isolation. The security of tokens deployed through the factory depends on the currently-audited versions of MoonsaleToken (MSL-006, 97/100) and MoonsaleLiquidityToken (MSL-005, 94/100); redeploying the factory with modified child contracts invalidates both this report's delegation assumptions and the child reports' validity.

For questions, clarifications, or a further re-assessment after additional remediation, contact ICOGemHunters through the channels published at the website listed on the cover page.

The Moonsale deployment pipeline is now fully audited and cleared. Future engagement scope could extend to off-chain components (factory UI, indexer correctness), additional token types added to the factory, or periodic re-audits of the deployed system after any upgrade.